

STATEMENT OF WORK (SOW)

PROJECT TITLE: Nursing Engagement Survey / Nursing Satisfaction Survey

DEPARTMENT: National Institutes of Health (NIH) Clinical Center (CC) Nursing Department (CCND)
Office of Nursing Professional Practice (NPP)

1. INTRODUCTION

The National Institutes of Health (NIH) Clinical Center (CC) is a 200-bed research hospital funded through the budgets of the individual institutes at the National Institutes of Health (NIH). In supporting approximately 1,600 active clinical research protocols, the NIH CC admits patients from around the country and, in some instances, from around the world, who participate in experimental treatments and studies to translate laboratory discoveries into better treatments, therapies, and interventions to improve the nation's health.

The Nursing Department is the nursing service at the NIH Clinical Center, the nation's largest clinical research hospital. The Nursing Department provides nursing care and clinical research support services to patients enrolled in clinical research trials conducted by intramural investigators at the National Institutes of Health's Bethesda campus. The Clinical Center Nursing Department (CCND) is organized into four clinical services: Medical Surgical Specialties (MSS), Neuroscience, Behavioral Health, & Pediatrics (NBHP), Oncology and Critical Care Services (OCC) and Nursing Operations (NOPS). As integral research team members and clinical care providers, the CC's Clinical Research Nurses (CRN) support the design, coordination, implementation, and dissemination of clinical research by NIH investigators with a strong focus on patient safety, continuity of care, and informed participation.

1.1. BACKGROUND

In 2024, the NIH Clinical Center was awarded Magnet® with Distinction by the American Nurses Credentialing Center (ANCC), a top-tier category received by only the top 1 percent of hospitals in the United States. This elite designation signals to our current and future scientific investigators, patients/families, and employees that the Clinical Center is committed to only the highest quality clinical research care and thus, this designation becomes an important recruitment tool.

The Magnet® with Distinction designation, however, is not a permanent status. Documentation of sustained outperformance of clinical and operational metrics must be submitted every 4 years to the ANCC including the results of an annual nursing excellence survey administered to eligible nursing staff. Nursing excellence surveys gather nurses' perceptions about their work environment and the resources provided by the hospital in support of high quality and safe patient care.

Therefore, the NIH CC Nursing Department shall conduct periodic surveys of eligible nurses employed by the Clinical Center who work in a variety of clinical settings (e.g., inpatient units, outpatient clinics, day hospitals, surgical and procedure locations, etc.). The purpose of the periodic surveys is to ascertain their perceptions of their work environment, and the quality of resources provided in support of patient care. Data gathered from these surveys will be used to make improvements and survey results will be submitted to the ANCC as required to maintain the designation, Magnet® with Distinction.

1.2. SCOPE

The purpose of these surveys is to obtain information from nursing staff on several issues such as:

1. Subject demographics
2. Adequacy of Resources & Staffing
3. Autonomy
4. Fundamentals of Quality Nursing Care
5. Interprofessional Relationships
6. Leadership Access and Responsiveness
7. Professional Development
8. RN to RN Teamwork & Collaboration

1.3 OBJECTIVES

1. A nursing survey shall meet the American Nurses Credentialing Center Magnet Recognition Program® requirements as required and provide robust, benchmarkable data for analysis.
2. A nursing survey whose demographic questions can be suppressed as required by the federal government but do not impact the validity or reliability of the seven (7) survey categories.
3. All data collected shall be available to the NIH CC and other NIH Institutes and Centers for dissemination, analysis, action, and public reporting (as necessary).
4. Survey results shall allow the NIH CC to identify and focus its attention on the nurse satisfaction and engagement categories that need improvement. In addition, data from the surveys shall provide the NIH CC with opportunities for relevant external benchmarking.
5. Survey results shall be submitted to the ANCC as required to maintain the Magnet® with Distinction designation.

1.4 PERIODS OF PERFORMANCE

The Period of Performance for this project shall consist of a Base Period of twelve (12) months and four (4) one (1) year Option Periods as listed below:

1. **BASE PERIOD:** January 01, 2026 to December 31, 2026
2. **OPTION PERIOD # 1:** January 01, 2027 to December 31, 2027
3. **OPTION PERIOD # 2:** January 01, 2028 to December 31, 2028
4. **OPTION PERIOD # 3:** January 01, 2029 to December 31, 2029
5. **OPTION PERIOD # 4:** January 01, 2030 to December 31, 2030

2. REFERENCES

- a) ANCC Magnet Recognition Program® <https://www.nursingworld.org/organizational-programs/magnet/>
- b) ANCC Magnet® Vendor Contact Information <https://www.nursingworld.org/globalassets/organizational-programs/magnet/vendor-contact-info/vendor-contact-information.pdf>

3. REQUIREMENTS

- a) ANCC Magnet Recognition Program®-compliant vendor for all related services including RN Satisfaction/RN Engagement.
- b) Contractor shall collaborate with the ANCC Magnet Recognition Program® on alignment of questions to categories included in Section 1.2 Scope and meet Program requirements.
- c) Contractor shall collaborate with the NIH Clinical Center to suppress demographic questions as required by the government but do not impact the validity or reliability of the seven (7) survey categories.
- d) Survey tools fielded in English and validated if requested by the Clinical Center.
- e) Robust, nationally benchmarkable, comparative data set. Ownership rights shall be addressed in Section 10.
- f) The identity of survey respondents will remain confidential such that the NIH Clinical Center Nursing Department cannot trace responses back to an individual or group of individuals.
- g) Data must be available in a variety of formats including raw data and graphs that meet ANCC Magnet® specifications.
- h) Data shall be provided to the NIH in XML file at the end of the contract, if the contract is not renewed.
- i) Data must be handled in accordance with federal records management and privacy laws and may not be retained, used, sold, or disclosed beyond contract authorization. Upon contract completion, all Government data shall be returned to NIH or disposed of as directed, in accordance with approved retention schedules (e.g., NARA). Also see appendices.

- j) Contractor shall demonstrate the ability to meet federal information security requirements as outlined in Appendix A

4. TASKS

The contractor shall conduct the following tasks:

TASK 1: ANNUAL MONITORING OF NURSING PERCEPTIONS

SUBTASK 1.1. With input from NIH CC Nursing Department, the Contractor shall administer surveys (data collection and management) using survey questions approved by the ANCC and provide benchmarked data fielded to all available academic medical centers and nationally recognized hospitals. Benchmark data shall be provided by the Contractor.

SUBTASK 1.2. Using appropriate surveying methodologies, the Contractor shall administer surveys to eligible nursing staff at the NIH Clinical Center annually or as required by the ANCC Magnet Recognition Program®. Survey invitations shall be sent to official government email accounts, and responses must be submitted through a secure, authorized platform. Surveys may be completed on a government-furnished or personal device, provided applicable security requirements are met. Two or 3 reminder invitations can be sent to eligible nursing staff. Participation rates shall be available daily throughout the survey period and at the conclusion of the survey.

SUBTASK 1.3. Survey results shall be available to the NIH Clinical Center within five (5) days after the survey closes. Data reports in the ANCC Magnet® approved format will be ready within two weeks after the survey closes. A common measure of central tendency (e.g., mean or median) will be provided to display NIH Clinical Center and benchmark data. Survey results shall be available to NIH CC Nursing Department employees on a electronic dashboard.

SUBTASK 1.4. The Government shall pay only for services rendered and reserves the right not to administer a survey in a year when the NIH CC Nursing Department has outperformed on four of the seven categories listed in item 1.2 Scope.

TASK 2: PULSE SURVEYS

SUBTASK 2.1. The Contractor shall assist the NIH CC Nursing Department in the administration of a pulse survey that is nationally benchmarked to demonstrate outperformance in one or more of the ANCC approved categories.

SUBTASK 2.2. Using appropriate survey methodologies, the pulse survey shall be administered to all eligible nursing staff in one or more clinical settings (e.g., inpatient units, outpatient clinics, day hospitals, surgical and procedure locations, etc.). Survey invitations shall be sent in real time to official government email accounts to support timely performance improvement and quality assurance. Responses must be submitted through a secure, authorized platform and may be completed using a government-furnished or personal device, provided applicable security requirements are met.

SUBTASK 2.3. Pulse survey results will be available to the NIH Clinical Center Nursing Department within five (5) days after the survey closes. Data reports in the ANCC Magnet® approved format will be ready within two (2) weeks after the pulse survey closes. A common measure of central tendency (e.g., mean or median) will be provided to display NIH Clinical Center and benchmark data. Survey results shall be available to NIH CC Nursing Department employees on an electronic dashboard.

SUBTASK 2.4. The pulse surveys shall be coordinated with the survey activities in Task 1.

TASK 3: REPORTS AND DISTRIBUTION OF DATA

SUBTASK 3.1. The Contractor shall complete data entry and data analysis. Reporting shall be via secured https:// internet access in either an Excel spreadsheet, Microsoft Word, Access, or .pdf format. Reporting includes action plan reports to address specific areas of concern, incorporating current leading practices in hospital management, patient safety, and clinical care. Nursing comments (if applicable) shall be organized into topics.

SUBTASK 3.2. Contractor shall maintain an online, password-protected, federally compliant database that securely stores survey data and supports searchable access, data downloads, and the generation of specialized reports upon request. Database shall allow for robust data analysis.

TASK 4: MAINTAIN PRIVACY

SUBTASK 4.1. The Contractor shall safeguard all PII and maintain its confidentiality by implementing and maintaining appropriate administrative, technical, and physical security controls in compliance with all applicable NIH, HHS, and Federal security and privacy laws, regulations, and policies, including but not limited to FISMA, the Privacy Act of 1974, and NIST SP 800-53. Also see appendices.

SUBTASK 4.2: In collaboration with the NIH Clinical Center Nursing Department, the Contractor will support strategies that guarantee all clinical locations and/or role groups will receive survey data such that the identity of one or more individuals remains deidentified and confidential (e.g., combining clinical locations to maximize sample size).

SUBTASK 4.3. The Contractor shall ensure that all data is securely collected, accessed, used, transmitted, stored, and maintained in compliance with all applicable NIH, HHS, and Federal security and privacy laws, regulations, and policies, as detailed in the Appendices of this SOW.

SUBTASK 4.4. The Contractor shall require that all employees and agents of the Contractor who have access to such employee Information shall execute Contractor's non-disclosure agreement or other agreement with confidential obligations or, ensure access to NIH data is limited to authorized personnel with a validated need-to-know, least privilege, and multi-factor authentication (MFA) for all privileged, administrative, and remote access.

SUBTASK 4.4. Contractor shall not refer to the NIH or any of its affiliates, employees, agents, or medical or research staff in any press release or promotional statements without the prior written approval of the NIH Contracting Officer (CO).

SUBTASK 4.5. The NIH Clinical Center shall not refer to the Contractor, or any of its affiliates, employees, agents, or medical or research staff in any press release or promotional statements without the prior written approval of the Contractor.

5. CONTRACTOR SERVICE SUMMARY

a. CONTRACTOR. Contractor shall:

- Display reports in a manner that supports American Nursing Credentialing Center (ANCC) 2023 Magnet® Application Manual, or subsequent versions as they are released (ANCC Magnet® Application Manual).
- Subject to availability, reports displayed shall include the most current reporting period and cover the given time periods as defined by the current ANCC Magnet® Application Manual.
- Provide educational materials related to the application.
- Deliver the survey data via secure web application.
- Provide a non-exclusive, limited, non-transferable, non-assignable, non-source code license to use Contractor's Nursing Experience web-based application(s), for an unlimited number of users at each facility.

b. ADVISOR SUPPORT. Contractor shall use commercially reasonable efforts to provide access to Advisory services which shall:

- Provide NIH CC with access to advisory support from a knowledgeable subject matter expert(s) ("Advisors").
- Provide NIH CC access to an Advisor who shall troubleshoot questions from users regarding system functionality.
- Provide access to an Advisor who can collaborate and leverage their expertise to respond to NIH CC's questions about their journey toward clinical and nursing excellence.

c. EDUCATION & TRAINING. Contractor shall:

- Provide NIH CC with unit enrollment and system functionality training.
- Provide access to quality improvement virtual and on-demand education.
- Provide access to tutorials and training modules.

d. SUPPORT DESK. Contractor shall provide access to the NIH CC support desk who shall:

- Provide virtual, real time NIH CC user assistance, Monday – Friday, 8:00 a.m. – 8:00 p.m. (EDT).

- Provide virtual, real-time NIH Clinical Center user assistance 24/7 during the survey and any pulse survey period to ensure respondents can resolve technical issues and complete survey.

6. SERVICE ASSURANCE

- a. **CONTRACTOR HOURS OF OPERATIONS.** Contractor shall provide access to our associates Monday – Friday, 8:00 a.m. – 5:00 p.m. (EDT).
- b. **GOVERNMENT HOLIDAYS.** Of the eleven (11) federal government holidays, the Contractor recognizes the following nine (9), and all offices are closed on these days or their days of observance:
 - New Year’s Day (January 1)
 - Martin Luther King Day (third Monday in January)
 - Memorial Day (last Monday in May)
 - Independence Day (July 4)
 - Labor Day (first Monday in September)
 - Thanksgiving (fourth Thursday in November)
 - Day after Thanksgiving
 - Christmas Eve (December 24)
 - Christmas (December 25)
- c. **FEDERAL CLOSURES.** Contractor services may be impacted by federal closures, such as federal holidays, federal shutdown, states of emergency, severe weather, or natural disaster. Every effort shall be made to notify the NIH CC and return to normal business operations once the federal closure ends. The timing for this return to normal business operations shall be dependent upon the cause and duration of the closure as well as the resulting aftermath.
- d. **OTHER CLOSURES.** There may be occasions where Contractor closes all offices, such as for a corporate meeting or a day of community service. If these instances occur, the NIH CC shall be notified by Contractor a minimum of thirty (30) days in advance of such a closure.

7. NIH CLINICAL CENTER RESPONSIBILITIES AND ACKNOWLEDGEMENTS

- a. In circumstances when there is a potential or actual sample size less than five (5), the NIH Clinical Center Nursing Department will combine locations.
- b. Obtain any and all consents, authorizations, and/or approvals required by applicable laws, rules, regulations or policy to enable Contractor to execute its obligations under this Agreement.
- c. NIH CC acknowledges that it must comply with certain hardware and software requirements to receive Contractor’s online services, as amended from time to time.
- d. NIH CC shall designate a primary root user for the Contractor online system and applications who is responsible for user access and management of users within their organization.
- e. NIH CC shall ensure that all access to any and all Contractor online systems is immediately terminated upon an employee’s departure from the NIH CC’s facility or organization.
- f. Contractor does not warrant or represent that the services provided pursuant to this SOW shall be capable of achieving any particular result in the NIH Clinical Center’s business, including maintaining ANCC Magnet Recognition Program®.

8. END RESULTS/DELIVERABLES

The Contractor shall administer surveys of staff and provide the Government with access to survey data through the Contractor’s secure portal. The Contractor shall support the generation of reports on a daily, monthly, and quarterly basis, as needed.

9. PROGRESS/COMPLIANCE

The Government requires the following from Contractors to monitor progress and ensure compliance:

- Weekly Progress Report for new projects until implementation to include implementation set-up calls and project tracking for set-up by required deadlines.
- Progress Reports and Project Tracking documents to be delivered following set-up meetings by email to the NIH liaison currently in the Clinical Center Nursing Department Office of Nursing Professional Practice. Progress Reports and Project Tracking documents will outline action items and assigned accountability.
- The contractor must remain an ANCC-approved vendor for the duration of the contract, unless the Government determines that this is no longer necessary.

10. OWNERSHIP AND INTELLECTUAL PROPERTY

- a. Unless specifically provided otherwise in a SOW (in which case that specific exception shall apply only to the SOW that includes that exception and not any other SOWs), the Parties acknowledge and agree that any NIH-specific reports (including quarterly reports and any report created by NIH using a Contractor online application) and NIH-specific data analyses created by Contractor for NIH under this Agreement (collectively, “Work Product”) shall be owned by the NIH. Subject to Section 10(b), below, all right, title and interest in the Work Product shall vest in NIH and all Work Product shall be deemed to be works made for hire for NIH.
- b. Notwithstanding anything to the contrary in Section 10(a), Contractor owns, and reserves all rights in and to, the Contractor Knowledge Base Materials. The phrase “Contractor Knowledge Base Materials” shall mean any survey questions, methodologies, comparative and benchmark databases and any related documentation generated by or on behalf of Contractor or any Contractor personnel (including, without limitation, all de-identified survey-level responses and other measures of nursing satisfaction) as well as any technology, software, code, processes, know-how, or tools that have independent value outside of the Work Product. In the event that the Work Product contains or references any Contractor Knowledge Base Materials, Contractor hereby grants to NIH a perpetual, non-exclusive, non-transferable, non-sublicensable, limited license to use or access those Contractor Knowledge Base Materials that may be contained in the Work Product solely for NIH’s own internal purposes. Contractor shall retain all right, title and interest (including, without limitation, all intellectual property rights) in and to the Contractor Knowledge Base Materials. NIH shall not, and shall not permit any third party to, (i) decompile, disassemble or reverse engineer the Contractor Knowledge Base Materials; (ii) modify the Contractor Knowledge Base Materials, or create any derivative product from any of the Contractor Knowledge Base Materials; (iii) use the Contractor Knowledge Base Materials except as incorporated into the Work Product; or (iv) market, sell or distribute the Contractor Knowledge Base Materials on a stand-alone basis or together with any other products or services. Any copy, modification, revision, enhancement, adaptation, translation, or derivative work of or created from the Contractor Knowledge Base Materials shall be owned solely and exclusively by Contractor, as shall any and all patent rights, copyrights, trade secret rights, trademark rights, and all other proprietary rights, worldwide therein and thereto, and NIH hereby assigns to Contractor any and all of its interests, title or ownership in the Contractor Knowledge Base Materials or any modification to or derivative work of the Contractor Knowledge Base Materials.
- c. NIH acknowledges and agrees that, pursuant to this Agreement, NIH has provided and continues to provide Contractor, or Contractor has otherwise collected or accessed and continues to collect or access on NIH’s behalf, certain data (including, but not limited to, employee uploads and responses) (collectively, “NIH Data”) in connection with Contractor’s performance of the Services for NIH or the exercise of Contractor’s rights under this Agreement. Notwithstanding anything to the contrary in this Agreement, the **BAA** (as defined below) or any other agreement or understanding between the Parties, and without limiting any other rights of Contractor with respect to NIH Data or PHI (as defined below) received from or created on behalf of NIH, including any rights set forth in the **BAA**, NIH hereby authorizes Contractor to de-identify NIH Data and to use, disclose and include that de-identified NIH Data within the Contractor Knowledge Base Materials. The Parties acknowledge and agree that de-identified NIH Data shall immediately cease to be NIH Data and shall become part of the Contractor Knowledge Base Materials. The Parties further acknowledge and agree that de-identified NIH Data no longer meets the definition of PHI and is therefore not subject to the provisions of the **BAA**. NIH shall not, and NIH shall not permit any third party to, attempt to re-identify any Contractor Knowledge Base Materials, including any de-identified NIH Data therein.
- d. NIH acknowledges and agrees that electronic, raw data files containing nursing-level responses, measurement or improvement scores or compilations thereof, that may be provided by Contractor to NIH (“Data Files”), also contain Contractor proprietary information and intellectual property. NIH may request, and Contractor may agree to provide NIH with access to the Data Files in a manner determined by Contractor after the Parties enter

into a separate data use agreement in the form and substance approved by Contractor. In the event that Contractor provides NIH with access to any Data Files, NIH agrees to: (i) only use the Data Files for its own internal purposes and not for the benefit of any third party; (ii) only share, disclose, or transmit the Data Files to a person who is an employee of NIH or has a written contractual relationship with NIH to provide further analysis of NIH's own internal business purposes; (iii) not, and NIH shall not permit any third party to, combine any of the information in the Data Files with other information to generate benchmarks; and (iv) not, and NIH shall not permit any third party to, share Data Files with any other entity that provides satisfaction/experience/engagement measurement reporting tools, services, or other activities or services similar or reasonably competitive to those offered by Contractor.

- e. Neither Party shall use the Marks of the other Party for any advertising, marketing, or endorsement without the prior written consent from such other Party; provided, however, that, without obtaining Contractor's prior written consent, NIH may use Contractor's Marks solely to promote its use of the Services provided by Contractor to NIH under this Agreement, provided that such use of Contractor's Marks shall be in compliance with Contractor's then-current branding usage guidelines available to NIH upon request. The foregoing notwithstanding, NIH grants Contractor the right to include NIH's name in Contractor's client list, including its list of participants in the database, and list of award winners, when applicable. A Party shall immediately cease using the Marks of the other Party in any manner found objectionable by that Party. As used in this Agreement, "Marks" means a Party's trademarks, service marks and associated logos. Each Party shall retain all right, title and interest in and to its Marks, and each Party's use of the other Party's Marks shall inure to the benefit of such other Party.

11. CONSENTS/AUTHORIZATIONS

- a. NIH hereby represents and warrants that it has obtained and shall continue to obtain and maintain throughout the Term, all necessary and required licenses, permits, consents, authorizations, and/or approvals required by applicable laws, rules, regulations or policies to enable Contractor's delivery of Services on NIH's behalf in accordance with those laws, rules, regulations or policies, including, but not limited to authorizations necessary for Contractor to perform the Services. For the avoidance of doubt, NIH represents and warrants that it has obtained and shall continue to obtain and maintain throughout the Term, the consents required by the Telephone Consumer Protection Act (TCPA) and the Federal Communications Commission's TCPA rules for Contractor to perform the Services using an automatic telephone dialing system, prerecorded or artificial voice, or other technologies.

12. INDEMNIFICATION AND LIMITATION OF LIABILITY

- a. **Indemnification.** Subject to the terms and conditions set forth herein, NIH shall indemnify, defend, and hold harmless Contractor, and its respective directors, officers, parent entities, subsidiaries, employees, shareholders, agents and its and their successors and assigns from and against any and all third-party claims, actions, suits, liabilities, judgments, losses, damages, reasonable costs, reasonable charges, reasonable attorneys' fees and/or expenses incurred or suffered by Contractor arising out of, relating to or in connection with (i) NIH's performance under this contract, including the acts, errors or omissions of any third party, (ii) NIH's breach of this Agreement, including, but not limited to, NIH's failure to obtain any consents or authorizations required by Section 6(a) or (iii) NIH's violation of applicable law. Contractor shall indemnify, defend, and hold harmless NIH, and its respective directors, officers, parent entities, subsidiaries, employees from and against any and all third-party claims, actions, losses, damages, and/or liability related to the infringement or misappropriation by Contractor of any patent, patent application issued or published on or before the Effective Date, copyright or trademark of a third party in the United States and for any related costs or expenses (including reasonable attorney's fees) incurred by NIH.
- b. **Limitation of Liability.** Notwithstanding any other provision of this Agreement or where this exclusion or restriction of liability would be void or ineffective under applicable law, in no event shall either Party be liable to the other under, in connection with or related to this Agreement for any special, indirect, consequential, exemplary or punitive damages (including, without limitation, loss of profits or revenues, loss of goods, penalties or withholding of reimbursement by a health care payer, state/federal agency or other entity) whether based on breach of contract, warranty, tort, product liability or any other legal theory, even if that Party has been advised of the possibility of such damages. The Parties further agree that, notwithstanding any other provision of this Agreement, the **BAA**, or any other agreement between the Parties or exhibit hereto, Contractor's total cumulative liability under, in connection with or related to this Agreement or in furtherance of the Agreement's provisions or objectives, including but not limited to liability under the **BAA** or any other agreement between the

Parties or exhibit hereto, shall be limited to actual, direct damages not to exceed the amount paid (less any refunds or credits) by NIH to Contractor during the twelve (12) month period preceding the date of the claim.

Appendix A: security requirements for information security and physical access security procurements

Applicability: The requirements herein apply whether the entire contract or modification (hereafter "contract"), or portion thereof, includes either or both of the following:

- **Access (Physical or Logical) to Government Information:** Contractor (and any Sub-Contractor) will have or will be given the ability to have, routine physical (entry) or logical (electronic) access to Government information and network(s).
- **Operate a Federal System Containing Information:** Contractor (and any Sub-Contractor) will operate a Federal system and information technology containing data that supports the HHS/NIH/CC mission. In addition to the *Federal Acquisition Regulation (FAR) Subpart 2.1* definition of "information technology" (IT), the term as used in this section includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources.

Requirements for Safeguarding Information and Information Systems:

- All Government information and information systems must be protected in accordance with Federal policies and level of risk. At a minimum, the Contractor (and any Sub-Contractor) must protect the:
 - Confidentiality, which means preserving authorized restrictions on access and disclosure, based on the security terms found in this contract, including means for protecting personal privacy and proprietary information;
 - Integrity, which means guarding against improper information modification or destruction, and ensuring information non-repudiation and authenticity; and
 - Availability, which means ensuring timely and reliable access to and use of information.
- Report any discovered or unanticipated threats or hazards by either the CC or Contractor, or if existing safeguards have ceased to function immediately after discovery, within one (1) hour or less, to the appropriate CC Federal representative(s).
- Adopt and implement all applicable policies, procedures, controls, and standards required by the NIH/CC to ensure the confidentiality, integrity, and availability (CIA) of Government information and Government information systems for which the Contractor is responsible under this contract or to which the Contractor may otherwise have access under this contract. Obtain all applicable security and privacy policies by contacting the CC CO/COR or CC security and CC privacy officials.

Privacy Act Requirements:

- The Contractor must comply with the *Privacy Act* requirements, the *E-Government Act of 2002*, *NIST SP 800-53*, and related NIH/CC privacy policies, and complete requirements set forth by the Government. Per the *Office of Management and Budget (OMB) Circular A-130*, Personally Identifiable Information (PII), is "information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual." Examples of PII include, but are not limited to the following: social security number, date and place of birth, mother's maiden name, biometric records, etc.

Controlled Unclassified Information (CUI) Requirements:

- *Executive Order 13556* defines controlled unclassified information (CUI) as "information that laws, regulations, or Government-wide policies require to have safeguarding or dissemination controls, excluding classified information." The Contractor (and any Sub-Contractor) must comply with *Executive Order 13556, Controlled Unclassified Information, (implemented at 3 CFR, part 2002) when handling CUI. 32 C.F.R. 2002.4(aa)*. Handling refers to any use of CUI, including but not limited to marking, safeguarding, transporting, disseminating, re-using, and disposing of the information, *81 Fed. Reg. 63323*.
- The requirements below apply only to non-Federal systems that process, store, or transmit CUI, or that provide security protection for such components. All sensitive information that has been identified as CUI by a regulation or statute, handled by this solicitation/contract, must be:
 - Marked appropriately;

- Disclosed to authorized personnel on a Need-To-Know basis;
- Protected in accordance with *NIST SP 800-53, Security and Privacy Controls for Information Systems and Organizations* applicable baseline if handled by a Contractor system operated on behalf of the agency, or *NIST SP 800-171, Protecting Controlled Unclassified Information in Non-Federal Information Systems and Organizations* if handled by internal Contractor system; and
- Returned to NIH/CC control, destroyed when no longer needed, or held until otherwise directed. Information and data must be disposed of in accordance with *NIST SP 800-88, Guidelines for Media Sanitization*.

Requirements for Protection of Sensitive Information:

- For security purposes, information is or may be sensitive because it requires security to protect its confidentiality, integrity, and availability. The Contractor (and any Sub-Contractor) must protect all Government information that is or may be sensitive by securing it with a solution that is validated with current *FIPS 140* validation certificate from the *NIST Cryptographic Module Validation Program (CMVP)*.

Confidentiality and Nondisclosure of Information:

- Any information provided to the Contractor (and any Sub-Contractor) by NIH/CC or collected by the Contractor on behalf of the Government must be used only for the purpose of carrying out the provisions of this contract and must not be disclosed or made known in any manner to any persons except as may be necessary in the performance of the contract. The Contractor assumes responsibility for protection of the confidentiality of Government records and must ensure that all work performed by its employees and Sub-Contractors must be under the supervision of the Contractor. Each Contractor employee or any of its Sub-Contractors to whom any NIH/CC records may be made available or disclosed must be notified in writing by the Contractor that information disclosed to such employee or Sub-Contractor can be used only for that purpose and to the extent authorized herein.
- The confidentiality, integrity, and availability (CIA) of such information must be protected in accordance with Federal policies. Unauthorized disclosure of information will be subject to the HHS/NIH sanction policies and governed by the following laws and regulations:
 - 18 U.S.C. 641 (*Criminal Code: Public Money, Property or Records*);
 - 18 U.S.C. 1905 (*Criminal Code: Disclosure of Confidential Information*); and
 - 44 U.S.C. Chapter 35, Subchapter I (*Paperwork Reduction Act*).

Internet Protocol Version 6 (IPv6) Requirements:

- All procurements using Internet Protocol (IP) must comply with *OMB Memorandum M-21-07, Completing the Transition to Internet Protocol Version 6 (IPv6)* available at <https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>

Information and Communications Technology (ICT) Requirements:

- Information and Communications Technology (ICT) products and services from prohibited entities/sources must not be used/acquired in compliance with *Public Law 115-232, Section 889 Parts A and B, FAR 4.21, FAR 52.204.23, FAR 52.204.24, and FAR 52.204.25*. The Contractor (and any Sub-Contractor) must notify the Government if they identify prohibited ICT products and services are used during the contract performance.

Requirements for Government Websites:

- All new and existing public-facing Government websites must be securely configured with Hypertext Transfer Protocol Secure (HTTPS) using the most recent version of Transport Layer Security (TLS). In addition, HTTPS must enable HTTP Strict Transport Security (HSTS) to instruct compliant browsers to assume HTTPS at all times to reduce the number of insecure redirects and protect against attacks that attempt to downgrade connections to plain HTTP. For internal-facing websites, HTTPS is not required, but highly recommended. Consult the [HHS Policy for Internet and Email Security](#) for additional information.

Contract Documentation Requirements:

- The Contractor shall use provided templates, policies, forms, and other agency documents. The CC will specify which documents/forms will be provided for Contractor to comply with contract deliverables.

Standard for Encryption:

The Contractor (and any Sub-Contractor) must:

- Comply with the *HHS/NIH Standard for Encryption of Computing Devices and Information* to prevent unauthorized access to Government information.
- Encrypt all sensitive Federal data and information (i.e., PII, PHI, proprietary information, etc.) in transit (i.e., email, network connections, etc.) and at rest (i.e., servers, storage devices, mobile devices, backup media, etc.) with an encryption solution that is validated with current *FIPS 140* validation certificate from the *NIST Cryptographic Module Validation Program (CMVP)*.
- Secure all devices (i.e., desktops, laptops, mobile devices, etc.) that store and process Government information and ensure devices meet HHS and NIH/CC-specific encryption standard requirements. Maintain a complete and current inventory of all laptop computers, desktop computers, and other mobile devices and portable media that store or process sensitive Government information (including sensitive information, such as PII).
- Verify that the encryption solutions in use have been validated under the *NIST CMVP* to confirm compliance with current *FIPS 140* validation certificate from the *NIST CMVP*. The Contractor must provide a written copy of the validation documentation to the COR within thirty (30) days.
- Use the Key Management system on the NIH personal identification verification (PIV) card or establish and use a key recovery mechanism to ensure the ability for authorized personnel to encrypt/decrypt information and recover encryption keys <http://csrc.nist.gov/publications/>. Encryption keys must be provided to the COR upon request and at the conclusion of the contract.

Contractor Non-Disclosure Agreement (NDA) Requirements:

- Each Contractor (and any Sub-Contractor) employee having access to non-public Government information under this contract must complete and sign a NIH non-disclosure agreement (NDA). Contractors (and Sub-Contractors) must submit a copy of each signed and witnessed NDA to the Contracting Officer (CO) and CO Representative (COR) prior to performing any work under the acquisition.

Incident Response Requirements:

- The Contractor (and Sub-Contractor) must respond to all alerts/indicators of Compromise (IOCs) provided by HHS Computer Security Incident Response Center (CSIRC)/NIH Incident Response (IRT) teams within 24 hours, whether the response is positive or negative. In accordance with FISMA and OMB M-17-12, Preparing for and Responding to a Breach of Personally Identifiable Information (PII), an incident is "an occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies" and a privacy breach is "the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information or (2) an authorized user accesses or potentially accesses personally identifiable information for an other than authorized purpose." For additional information on the HHS breach response process, please see the HHS Policy and Plan for Preparing for and Responding to a Breach of Personally Identifiable Information (PII)."
- In the event of a suspected or confirmed incident or breach, the Contractor (and any Sub-Contractor) must:
 - Protect all sensitive information, including any PII created, stored, or transmitted in the performance of this contract, with encryption solution that is validated with current *FIPS 140* validation certificate from the *NIST CMVP*.
 - NOT notify affected individuals unless so instructed by the Contracting Officer or designated representative. If so instructed by the Contracting Officer or representative, the Contractor must send NIH approved notifications to affected individuals.
 - Report all suspected and confirmed information security and privacy incidents and breaches to the NIH Information Security Program, IRT Hotline (301.881.9726) COR, CO, ISSO, and any other Designated

Federal Officials, including breaches involving PII, in any medium or form, including paper, oral, or electronic, as soon as possible and without unreasonable delay, no later than one (1) hour, and consistent with the applicable HHS/NIH/CC policy and procedures, NIST standards and guidelines, as well as US-CERT notification guidelines. The types of information required in an incident report must include at a minimum: company and point of contact information, contact information, impact classifications/threat vector, and the type of information compromised. In addition, the Contractor must:

- ✓ Cooperate and exchange any information, as determined by the Agency, necessary to effectively manage or mitigate a suspected or confirmed breach;
 - ✓ Not include any sensitive information in the subject or body of any reporting e-mail; and
 - ✓ Encrypt sensitive information in attachments to email, media, etc.
- Comply with *OMB M-17-12, Preparing for and Responding to a Breach of Personally Identifiable Information*, and HHS/NIH privacy breach response policies when handling PII breaches.
 - Provide full access and cooperate on all activities as determined by the Government to ensure an effective incident response, including providing all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents. This may involve disconnecting the system processing, storing, or transmitting the sensitive information from the Internet or other networks or applying additional security controls. This may also involve physical access to Contractor facilities during a breach/incident investigation

Contract Initiation and Expiration:

- General Security Requirements. The Contractor (and any Sub-Contractor) must comply with information security and privacy requirements, *Enterprise Performance Life Cycle (EPLC)* processes, HHS/NIH/CC Enterprise Architecture (EA) requirements to ensure information is appropriately protected from initiation to expiration of the contract. All information systems development or enhancement tasks supported by the Contractor must follow the HHS EPLC framework and methodology in accordance with the *HHS Contract Closeout Guide (2012)*.
- System Documentation. Contractors (and Sub-Contractors) must follow and adhere to HHS System Development Life Cycle requirements, at a minimum, for system development and provide system documentation at designated intervals (specifically, at the expiration of the contract) within the EPLC that require artifact review and approval.
- Sanitization of Government Files and Information. As part of contract closeout and at expiration of the contract, the Contractor (and Sub-Contractor) must provide all required documentation to the CO and COR to certify that, at the Government's direction, all electronic and paper records are appropriately disposed of and all devices and media are sanitized in accordance with *NIST SP 800-88, Guidelines for Media Sanitization*.
- Notification. The Contractor (and any Sub-Contractor) must notify the CO, COR, and system ISSO within the timeline set forth within the contract, before an employee stops working under this contract.
- Contractor Responsibilities upon Physical Completion of the Contract. The Contractor (and any Sub-Contractors) must return all Government information and IT resources (i.e., Government information in non-Government-owned systems, media, and backup systems) acquired during the term of this contract to the CO and COR. Additionally, the Contractor must provide a certification that all Government information has been properly sanitized and purged from Contractor-owned systems, including backup systems and media used during contract performance, in accordance with Federal policies.
- The Contractor (and any Sub-Contractor) must perform and document the actions when an employee terminates work under this contract within. All documentation must be available to the CO and or COR upon request.

Records Management and Retention:

- The Contractor (and any Sub-Contractor) must maintain all information in accordance with *Executive Order 13556 -- Controlled Unclassified Information, National Archives and Records Administration (NARA)* records retention policies and schedules and *HHS Policy for Records Management* and Federal policies and must not dispose of any records unless authorized by the CC.
- In the event that a Contractor (and any Sub-Contractor) accidentally disposes of or destroys a record without proper authorization, he/she must document and report the incident in accordance with Federal policies.

Configuration Requirements:

- The Contractor shall adhere to Federal requirements, guidelines, and processes for configuration management, including adherence to change control processes.

Organizational Conflict of Interest (OCI)

- The Contractor and Subcontractor personnel performing work under this contract may receive, have access to or participate in the development of proprietary or source selection information (e.g., cost or pricing information, budget information or analyses, specifications, or work statements, etc.) or perform evaluation services which may create a current or subsequent Organizational Conflict of Interests (OCI) as defined in *FAR Subpart 9.5*. The Contractor shall notify the CC CO immediately whenever it becomes aware that such access or participation may result in any actual or potential OCI and shall promptly submit a plan to the CC CO to avoid or mitigate any such OCI. The Contractor's mitigation plan will be determined to be acceptable solely at the discretion of the CC CO and in the event the CC CO unilaterally determines that any such OCI cannot be satisfactorily avoided or mitigated, the CC CO may affect other remedies as he or she deems necessary, including prohibiting the Contractor from participation in subsequent contracted requirements which may be affected by the OCI.

Appendix B: security requirements for procurements involving privacy act records

Privacy Act Requirements:

- Per the *Office of Management and Budget (OMB) Circular A-130*, Personally Identifiable Information (PII), is "information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual." Examples of PII include, but are not limited to the following: social security number, date and place of birth, mother's maiden name, biometric records, etc.
- It has been determined that this contract is subject to the *Privacy Act of 1974*, because this contract provides for the design, development, or operation of a system of records about individuals from which records are retrieved by name or other identifying particular.

Appendix C: security requirements for Government-owned, Contractor-operated (GOCO) and Contractor owned, contract operated (COCO) systems

1. Security Requirements for GOCO and COCO Resources

- a. **Federal Policies.** The Contractor (and any Sub-Contractor) must comply with applicable Federal laws and policies that include, but are not limited to, the *HHS Information Security and Privacy Policy (IS2P)*, *NIH InfoSec Handbook (latest version)*; *Federal Information Security Modernization Act (FISMA) of 2014, (44 U.S.C. 101)*; *National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, latest revision, Security and Privacy Controls for Information Systems and Organizations*; *Office of Management and Budget (OMB) Circular A-130, Managing Information as a Strategic Resource*; *FAR 24.301*, and other applicable Federal laws, regulations, NIST guidance, and Departmental policies.
- b. **Assessment and Authorization (A&A).** A valid authority to operate (ATO) certifies that the Contractor's information system meets the contract's requirements to protect the agency data. If the system under this contract does not have a valid ATO, the Contractor (and any Sub-Contractor) must work with the CC and supply the deliverables required to complete the ATO within the specified timeline(s). The Contractor must conduct the A&A requirements in accordance with *HHS IS2P*, *NIH InfoSec Handbook (latest version)*, *NIST SP 800-37, Guide for Applying the Risk Management Framework to Information Systems: A Security Life Cycle Approach (latest revision)*, *NIST SP 800-53B, Control Baselines for Information Systems and Organizations*, and the *NIST SP 800-53A (latest revision)*.

For existing ATOs, the CC Designated Federal Official will make a determination if the system needs to be re-authorized.

CC acceptance of the ATO does not alleviate the Contractor's responsibility to ensure the system security and privacy controls are implemented and operating effectively.

- i. **A&A Package Deliverables** - The Contractor (and any Sub-Contractor) must provide an A&A package within the specified timeline(s) to the Designated Federal Official. The following A&A deliverables are required to complete the A&A package:
 - **System Security Plan (SSP)** - The SSP must comply with the *NIST SP 800-18, Guide for Developing Security Plans for Federal Information Systems*, the *Federal Information Processing Standard (FIPS) 200, Recommended Security Controls for Information Systems*, and *NIST SP 800-53, Security and Privacy Controls for Federal Information Systems and Organizations* applicable baseline requirements, and other applicable NIST guidance as well as Federal policies and other guidance. The SSP must be consistent with and detail the approach to IT security contained in the Contractor's bid or proposal that resulted in the award of this contract. The SSP must provide an overview of the system environment and security requirements to protect the information system as well as describe all applicable security controls in place or planned for meeting those requirements. It should provide a structured process for planning adequate, cost-effective security protection for a system. The Contractor must review and update the SSP at least **annually** thereafter and if requested, provide a copy of the updated SSP.
 - **Security Assessment Plan/Report (SAP/SAR)** - The security assessment must be conducted by the assigned contract assessor and be consistent with *NIST SP 800-53A*, *NIST SP 800-30*, and related HHS and NIH CC policies. The assigned contract assessor will document the assessment results in the SAR. Thereafter, the Contractor, in coordination with the CC-Designated Federal Official must conduct and assist in the assessment of the security controls and update the SAR at least **annually**. A copy of the updated SAR should be provided if requested.
 - **Independent Assessment** - The Contractor (and Sub-Contractor) must have an independent third-party validate the security and privacy controls in place for the system(s) commensurate with the risk levels per *NIST SP 800-53B*. The independent third party must review and analyze the Security Authorization package, and report on technical, operational, and management level deficiencies as outlined in *NIST SP 800-53*. The Contractor must address all "high" deficiencies before submitting the package to the Government for acceptance and document all remaining deficiencies in a system Plan of Actions and Milestones (POA&M).
 - **POA&M** - All critical-risk weaknesses must be mitigated within the timeline set forth by the Designated CC official, high-risk weaknesses must be mitigated within the timeline

set forth by the Designated CC official, medium weaknesses must be mitigated within the timeline set forth by the Designated CC official, and low weaknesses must be mitigated within the timeline set forth by the Designated CC official, from the date the weaknesses are formally identified and documented. CC will determine the risk rating of vulnerabilities. Identified risks stemming from deficiencies related to the security control baseline implementation, assessment, continuous monitoring, vulnerability scanning, flaws and security defect in a system (that require to create a patch for remediation), and other security reviews and sources, as documented in the SAR, must be documented and tracked by the Contractor for mitigation in the POA&M document consistent with the HHS Standard for Plan of Action and Milestones and Federal policies. Depending on the severity of the risks, the CC may require designated POA&M weaknesses to be remediated before an ATO is issued. Thereafter, continue to remediate weaknesses throughout the contract. The POA&M document must be updated at least **quarterly**.

- **Contingency Plan and Contingency Plan Test** - The Contingency Plan must be developed in accordance with *NIST SP 800-34, Contingency Planning Guide for Federal Information Systems*, and be consistent with HHS and Federal policies. Upon acceptance by the CC System Owner, the Contractor, in coordination with the System Owner, must test the Contingency Plan and prepare a Contingency Plan Test Report that includes the test results, lessons learned and any action items that need to be addressed. Thereafter, the Contractor must update and test the Contingency Plan at least **annually**.
 - **E-Authentication Questionnaire** - The Contractor (and any Sub-Contractor) must collaborate with CC Government personnel to ensure that the E-Authentication requirements are implemented in accordance with *OMB 04-04 and NIST SP 800-63 B*.
 - Based on the level of assurance determined by the E-Auth, the Contractor (and Sub-Contractor) must ensure appropriate authentication to the system, including remote authentication, is in-place in accordance with the assurance level determined by the E-Auth (when required by the Government) in accordance with *HHS Guidance for Selection of e-Authentication Assurance Levels* and any other applicable HHS/NIH policies.
- ii. **Information Security Continuous Monitoring.** Upon the Government issuance of an Authority to Operate (ATO), the Contractor (and Sub-Contractor)-owned/operated systems that input, store, process, output, and transmit Government information, must meet, or exceed the information security continuous monitoring (ISCM) requirements in accordance with *FISMA and NIST SP 800-137, Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations, HHS ISCM Strategy, and HHS IS2P*.
- iii. **Annual Assessment/Penetration (Pen) Test** - Assess the system security and privacy controls (or ensure an assessment of the controls is conducted) at least annually to determine the implemented security and privacy controls are operating as intended and producing the desired results (this involves penetration testing conducted by the agency or independent third-party.) In addition, review all relevant A&A documentation (SSP, POA&M, Contingency Plan, etc.) and provide updates by due date set forth by the Government.
- iv. **Asset Management** - Using any available Security Content Automation Protocol (SCAP)-compliant automated tools for active/passive scans, provide an inventory of all information technology (IT) assets for hardware and software, (computers, servers, routers, databases, operating systems, etc.) that are processing NIH/CC-owned information/data. The deadline for providing this inventory information will be set forth by the Designated Federal Official. IT asset inventory information must include IP address, machine name, operating system level, security patch level, and SCAP-compliant format information. The Contractor must maintain a capability to provide an inventory of 100% of its IT assets using SCAP-compliant automated tools in accordance with the *HHS Policy for Information Technology Asset Management (ITAM)* and any other applicable HHS/NIH policy.
- v. **Configuration Management** - Use available SCAP-compliant automated tools as per *NIST IR 7511 and HHS Minimum Security Configurations Standards Guidance* to scan all IT assets, including but not limited to: computers, servers, routers, databases, operating systems, application, etc., that store and process Government information. Provide scan reports to the CC

- upon request. The Contractor must maintain a capability to provide security configuration compliance information for 100% of its IT assets using SCAP-compliant automated tools.
- vi. **Vulnerability Management** - Contractors must actively manage system vulnerabilities using automated tools and technologies where practicable and in accordance with *HHS Policy for Vulnerability Management*. Automated tools must be compliant with NIST-specified SCAP standards for vulnerability identification and management. The Contractor must maintain a capability to provide security vulnerability scanning information for 100% of IT assets using SCAP-compliant automated tools and report to the CC upon request.
 - vii. **Patching and Vulnerability Remediation** - Install vendor released security patches and remediate critical and high vulnerabilities in systems processing Government information in an expedited manner, within vendor and NIH/CC specified timeframes.
 - viii. **Secure Coding** - Follow the *HHS Policy for Software Development Secure Coding Practices* and secure coding best practice requirements, as directed by *United States Computer Emergency Readiness Team (US-CERT) specified standards* and the *Open Web Application Security Project (OWASP)*, that will limit system software vulnerability exploits.
 - ix. **Boundary Protection** - The Contractor must ensure that Government information, other than unrestricted information, being transmitted from Federal Government entities to external entities is routed through a Trusted Internet Connection (TIC).
- c. **Government Access for Security Assessment.** In addition to the Inspection Clause in the contract, the Contractor (and any Sub-Contractor) must afford the Government access to the Contractor's facilities, installations, operations, documentation, information systems, and personnel used in performance of this contract to the extent required to carry out a program of security assessment (to include vulnerability testing), investigation, and audit to safeguard against threats and hazards to the confidentiality, integrity, and availability of Federal data or to the protection of information systems operated on behalf of NIH/CC, including but are not limited to:
- i. At any tier handling or accessing information, consent to and allow the Government, or an independent third party working at the Government's direction, without notice at any time during a weekday during regular business hours Contractor local time, to access Contractor and Sub-Contractor installations, facilities, infrastructure, data centers, equipment (including but not limited to all servers, computing devices, and portable media), operations, documentation (whether in electronic, paper, or other forms), databases, and personnel which are used in performance of the contract. The Government includes but is not limited to the U.S. Department of Justice, U.S. Government Accountability Office, and the HHS Office of the Inspector General (OIG). The purpose of the access is to facilitate performance inspections and reviews, security and compliance audits, and law enforcement investigations. For security audits, the audit may include but not be limited to such items as buffer overflows, open ports, unnecessary services, lack of user input filtering, cross site scripting vulnerabilities, SQL injection vulnerabilities, and any other known vulnerabilities.
 - ii. At any tier handling or accessing protected information, fully cooperate with all audits, inspections, investigations, forensic analysis, or other reviews or requirements needed to carry out requirements presented in applicable law or policy. Beyond providing access, full cooperation also includes, but is not limited to, disclosure to investigators of information sufficient to identify the nature and extent of any criminal or fraudulent activity and the individuals responsible for that activity. It includes timely and complete production of requested data, metadata, information, and records relevant to any inspection, audit, investigation, or review, and making employees of the Contractor available for interview by inspectors, auditors, and investigators upon request. Full cooperation also includes allowing the Government to make reproductions or copies of information and equipment, including, if necessary, collecting a machine or system image capture.
 - Segregate Government protected information and metadata on the handling of Government protected information from other information. Commingling of information is prohibited. Inspectors, auditors, and investigators will not be precluded from having access to the sought information if sought information is commingled with other information.
 - Cooperate with inspections, audits, investigations, and reviews.
- d. **End of Life Compliance.** The Contractor (and any Sub-Contractor) must use Commercial off the Shelf (COTS) software or other software that is supported by the manufacturer. In addition, the COTS/other software need to be within one major version of the current version; deviation from this requirement will

only be allowed via the NIH/CC waiver process (approved by NIH CISO if it impacts NIH enterprise-wide systems and services, or by the CC CISO if it impacts only the NIH CC). The Contractor must retire and upgrade all software/systems that have reached end-of-life in accordance with *HHS End of Life Operating Systems, Software and Application Policy*.

- e. **Desktops, Laptops, and Other Computing Devices Required for Use by the Contractor.** The Contractor (and any Sub-Contractor) must ensure that all IT equipment (e.g., laptops, desktops, servers, routers, mobile devices, peripheral devices, etc.) used to process information on behalf of NIH/CC are deployed and operated in accordance with approved security configurations and meet the following minimum requirements:
 - i. Encrypt equipment and sensitive information stored and processed by such equipment in accordance with HHS encryption standard and current FIPS 140 validation certificate from the *NIST CMVP*.
 - ii. Configure laptops and desktops in accordance with the latest applicable *United States Government Configuration Baseline (USGCB)*, and *HHS/NIH Minimum Security Configuration Standards*;
 - iii. Maintain the latest operating system patch release and anti-virus software definitions;
 - iv. Validate the configuration settings after hardware and software installation, operation, maintenance, update, and patching and ensure changes in hardware and software do not alter the approved configuration settings; and
 - v. Automate configuration settings and configuration management in accordance with HHS/NIH security policies, including but not limited to:
 - Configuring its systems to allow for periodic NIH/CC vulnerability and security configuration assessment scanning; and
 - Using Security Content Automation Protocol (SCAP)-validated tools with capabilities to scan its systems at least on a monthly basis and report the results of these scans to the CO and COR, Project Officer, and any other applicable designated POC.
- f. **Rights to Data.** All contracts that require data to be produced, furnished, acquired, or used in meeting contract performance requirements, must contain terms that delineate the respective rights and obligations of the Government and the Contractor regarding the use, reproduction, and disclosure of that data. Data rights clauses do not specify the type, quantity or quality of data that is to be delivered, but only the respective rights of the Government and the Contractor regarding the use, disclosure, or reproduction of the data. Accordingly, the contract shall specify the data to be delivered.
- g. **Information and Communications Technology (ICT) Cybersecurity Supply Chain Risk Management (C-SCRM) requirements.** The Contractor (and any Sub-Contractor) must secure their ICT supply chain in compliance with *HHS Policy for Cyber Supply Chain Risk Management* and *Public Law 115-232 § 889*. At a minimum, they must implement the following:
 - i. Develop rules for suppliers' development methods, techniques, or practices;
 - ii. Use of secondary market components;
 - iii. Prohibit counterfeit products;
 - iv. Dispose and retain elements such as components, data, or intellectual property securely;
 - v. Ensure adequate supply of components;
 - vi. Require external providers handling Federal information or operating systems on behalf of the Federal Government to meet the same security and privacy requirements as Federal agencies;
 - vii. Require external providers to express security and privacy requirements (including the controls for systems processing, storing, or transmitting Federal information) in contracts or other formal agreements;
 - viii. Establish Service Level Agreements (SLAs), patching vehicles and disclosure requirements in the case of a security incident or new vulnerability being discovered; and
 - ix. Ensure that the supplier applies same contractual requirements to any sub-Contractors/suppliers that they involve in the provision of the product or service to the customer; and
 - x. Prohibit the use of covered telecommunications and video surveillance equipment or services.

Appendix D: security requirements for cloud service procurements

1. HHS FedRAMP Privacy and Security Requirements

The Contractor (and any Sub-Contractor) must be responsible for the following privacy and security requirements:

- a. **FedRAMP Compliant ATO.** Comply with *FedRAMP Assessment and Authorization (A&A) requirements* and ensure the information system/service under this contract has a valid FedRAMP compliant (approved) authority to operate (ATO) in accordance with *Federal Information Processing Standard (FIPS) Publication 199* defined security categorization. If a FedRAMP compliant ATO has not been granted, the Contractor must submit a plan to obtain a FedRAMP compliant ATO by *the timeframe set forth by the Designated Federal Official*.
 - i. Implement applicable FedRAMP baseline controls commensurate with the agency-defined security categorization and the applicable FedRAMP security control baseline (www.FedRAMP.gov). The *HHS Information Security and Privacy Policy (IS2P)* and *HHS Cloud Computing and Federal Risk and Authorization Management Program (FedRAMP) Guidance* further define the baseline policies as well as roles and responsibilities. The Contractor must also implement a set of additional controls identified by the agency when applicable.
 - ii. A security control assessment must be conducted by a FedRAMP third-party assessment organization (3PAO) for the initial ATO and **annually** thereafter or whenever there is a significant change to the system's security posture in accordance with the FedRAMP Continuous Monitoring Plan.
- b. **Data Jurisdiction.** The Contractor must store all information within the security authorization boundary, data at rest or data backup, within the Continental United States (CONUS).
- c. **Service Level Agreements.** The Contractor must understand the terms of the service agreements that define the legal relationships between cloud customers and cloud providers and work with the CC to develop and maintain an SLA.
- d. **Interconnection Agreements/Memorandum of Agreements.** The Contractor must establish and maintain Interconnection Agreements and or Memorandum of Agreements/Understanding (MOU) in accordance with Federal policies.

2. Protection of Information in a Cloud Environment

- a. If Contractor (and any Sub-Contractor) personnel must remove any information from the primary work area, they must protect it to the same extent they would the proprietary data and company trade secrets and in accordance with HHS policy <https://www.hhs.gov/web/governance/digital-strategy/it-policy-archive/index.html>.
- b. CC will retain unrestricted rights to Federal data handled under this contract. Specifically, CC retains ownership of any user created/loaded data and applications collected, maintained, used, or operated on behalf of CC and hosted on Contractor's infrastructure, as well as maintains the right to request full copies of these at any time. If requested, data must be available to CC within **one (1) business day** from request date or within the timeframe specified otherwise. In addition, the data must be provided at no additional cost to CC.
- c. The Contractor (and any Sub-Contractor) must ensure that the facilities that house the network infrastructure are physically and logically secure in accordance with FedRAMP requirements and HHS/NIH policies.
- d. The Contractor must support a system of records in accordance with NARA-approved records schedule(s) and protection requirements for Federal agencies to manage their electronic records in accordance with 36 CFR § 1236.20 & 1236.22 (ref. a), including but not limited to the following:
 - i. Maintenance of links between records and metadata, and
 - ii. Categorization of records to manage retention and disposal, either through transfer of permanent records to NARA or deletion of temporary records in accordance with NARA-approved retention schedules.
- e. The disposition of all NIH/CC data must be at the written direction of NIH/CC. This may include documents returned to NIH control; destroyed; or held until otherwise directed by the designated Federal official. Items returned to the Government must be hand carried or sent by certified mail to the COR.
 - i. If the system involves the design, development, or operation of a system of records on individuals, the Contractor must comply with the Privacy Act requirements.

3. Assessment and Authorization (A&A) Process

- a. The Contractor (and any Sub-Contractor) must comply with HHS/NIH and FedRAMP requirements as mandated by Federal laws, regulations, and HHS/NIH policies, including making available any documentation, physical access, and logical access needed to support the A&A requirement. The level of

effort for the A&A is based on the system's *FIPS 199* security categorization and HHS/NIH/CC security policies.

- i. In addition to the FedRAMP compliant ATO, the Contractor must complete and maintain an agency A&A package to obtain agency ATO prior to system deployment/service implementation. The ATO must be approved by the *designated NIH/CC* authorizing official (AO) prior to implementation of system and service being acquired.
 - ii. CSP systems categorized as *Federal Information Processing Standards (FIPS) 199* high must leverage a FedRAMP accredited third-party assessment organization (3PAO); moderate impact CSP systems must make a best effort to use a FedRAMP accredited 3PAO but should not use self-assessment. CSP systems categorized as *FIPS 199* low impact may leverage a non-accredited, independent assessor.
 - iii. For all acquired cloud services, the A&A package must include *deliverables mentioned on the FedRAMP site*. Following the initial ATO, the Contractor must review and maintain the ATO in accordance with Federal policies.
- b. NIH/CC reserves the right to perform penetration testing on all systems operated on behalf of agency. If NIH/CC exercises this right, the Contractor (and any Sub-Contractor) must allow NIH/CC employees (and designated third parties) to conduct Security Assessment activities to include control reviews in accordance with NIH/CC requirements. Review activities include, but are not limited to, scanning operating systems, web applications, wireless scanning; network device scanning to include routers, switches, and firewall, and IDS/IPS; databases and other applicable systems, including general support structure, that support the processing, transportation, storage, or security of Government information for vulnerabilities.
 - c. The Contractor must identify any gaps between required *FedRAMP Security Control Baseline/Continuous Monitoring controls* and the Contractor's implementation status as documented in the Security Assessment Report and related Continuous Monitoring artifacts. In addition, the Contractor must document and track all gaps for mitigation in a Plan of Action and Milestones (POA&M) document. Depending on the severity of the risks, HHS may require remediation at the Contractor's expense, before CC issues an ATO.
 - d. The Contractor (and any Sub-Contractor) must mitigate security risks for which they are responsible, including those identified during A&A and continuous monitoring activities. All vulnerabilities and findings must be remediated, in accordance with timelines specified in the NIH/CC POA&M Standard, from discovery: (1) critical vulnerabilities no later than **fifteen (15) days** and (2) high vulnerabilities within **thirty (30) days** (3) medium vulnerabilities within **ninety (90) days** and (4) low vulnerabilities no later than **three hundred and sixty-five (365) days**. In the event a vulnerability or other risk finding cannot be mitigated within the prescribed timelines above, they must be added to the designated POA&M and mitigated within the newly designated timelines. CC will determine the risk rating of vulnerabilities using FedRAMP baselines.
 - e. **Revocation of a Cloud Service.** NIH/CC has the right to take action in response to the CSP's lack of compliance and increased level of risk. In the event the CSP fails to meet HHS/NIH and FedRAMP security and privacy requirements and there is an incident involving sensitive information, NIH/CC may suspend or revoke an existing agency ATO (either in part or in whole) and cease operations. If an ATO is suspended or revoked in accordance with this provision, the CO and COR may direct the CSP to take additional security measures to secure sensitive information. These measures may include restricting access to sensitive information on the Contractor information system under this contract. Restricting access may include disconnecting the system processing, storing, or transmitting the sensitive information from the Internet or other networks or applying additional security controls.

4. Reporting and Continuous Monitoring

- a. Following the initial ATOs, the Contractor (and any Sub-Contractor) must perform the minimum ongoing continuous monitoring activities specified below, submit required deliverables by the specified due dates, and meet with the system/service owner and other relevant stakeholders to discuss the ongoing continuous monitoring activities, findings, and other relevant matters. The CSP will work with the agency to schedule ongoing continuous monitoring activities.
- b. At a minimum, the Contractor must provide the following artifacts/deliverables on a monthly basis:
 - i. Operating system, database, Web application, and network vulnerability scan results;
 - ii. Updated POA&Ms;
 - iii. Any updated authorization package documentation as required by the annual attestation/assessment/review or as requested by the CC System Owner or AO, and;

- iv. Any configuration changes to the system and system components or CSP's cloud environment, that may impact NIH/CC's security posture. Changes to the configuration of the system, its components, or environment that may impact the security posture of the system under this contract must be approved by the agency

5. Configuration Baseline

- a. The Contractor must certify that applications are fully functional and operate correctly as intended on systems using *HHS Minimum Security Configurations Standards Guidance*. The standard installation, operation, maintenance, updates, and patching of software must not alter the configuration settings from the approved NIH/CC configuration baseline.
- b. The Contractor must use Security Content Automation Protocol (SCAP) validated tools with configuration baseline scanner capability to certify their products operate correctly with NIH/CC and NIST defined configurations and do not alter these settings.

6. Incident Reporting

- a. The Contractor (and Sub-Contractor) must provide an Incident and Breach Response Plan (IRP) in accordance with NIH/CC, OMB, and US-CERT requirements and obtain approval from the NIH/CC. In addition, the Contractor must follow the incident response and US-CERT reporting guidance contained in the FedRAMP Incident Communications.
- b. The Contractor (and any Sub-Contractor) must implement a program of inspection to safeguard against threats and hazards to the security, confidentiality, integrity, and availability of Federal data, afford NIH/CC access to its facilities, installations, technical capabilities, operations, documentation, records, and databases within 72 hours of notification. The program of inspection must include, but is not limited to:
 - i. Conduct authenticated and unauthenticated operating system/network/database/web application vulnerability scans. Automated scans can be performed by NIH/CC personnel, or agents acting on behalf of NIH/CC, using agency-operated equipment and specified tools. The Contractor may choose to run its own automated scans or audits, provided the scanning tools and configuration settings are compliant with NIST Security Content Automation Protocol (SCAP) standards and have been approved by the agency. The agency may request the Contractor's scanning results and, at the agency discretion, accept those in lieu of agency performed vulnerability scans.
 - ii. In the event an incident involving sensitive information occurs, cooperate on all required activities determined by the agency to ensure an effective incident, or breach response and provide all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents. In addition, the Contractor must follow the agency reporting procedures and document the steps it takes to contain and eradicate the incident, recover from the incident, and provide a post-incident report that includes at a minimum the following:
 - Company and point of contact name;
 - Contract information;
 - Impact classifications/threat vector;
 - Type of information compromised;
 - A summary of lessons learned; and
 - Explanation of the mitigation steps of exploited vulnerabilities to prevent similar incidents in the future.

7. Media Transport

- a. The Contractor and its employees must be accountable and document all activities associated with the transport of Government information, devices, and media transported outside controlled areas and facilities. These include information stored on digital and non-digital media (e.g., CD-ROM, tapes, etc.), mobile/portable devices (e.g., USB flash drives, external hard drives, and SD cards)
- b. All information, devices and media must be encrypted with HHS-approved encryption mechanisms to protect the confidentiality, integrity, and availability of all Government information transported outside of controlled facilities.

8. Boundary Protection: Trusted Internet Connections (TIC)

- a. The Contractor must ensure that Government information, other than unrestricted information, being transmitted from Federal Government entities to external entities using cloud services is inspected by Trusted Internet Connection (TIC) processes that are in compliance with the requirements of the *Office of Management and Budget (OMB) Memorandum (M) 19-26: Update to the TIC Initiative, TIC 3.0*.
- b. The Contractor must route all external connections through a TIC.

- c. **Non-Repudiation.** The Contractor must provide a system that implements encryption with current FIPS 140 validation certificate from the NIST CMVP that provides for origin authentication, data integrity, and signer non-repudiation.

9. CC-Specific Information Security Requirements:

- a. The Contractor is required to adhere to CC-specific information security requirements, which align with those set forth within the NIH Information Security Handbook (NIH Access Required).
- b. The Contractor shall complete the CC Minimum Security Questionnaire which includes an overview of the system, roles and responsibilities, and configurations.
- c. The Contractor shall ensure the system is registered and kept current in the NIH Governance, Risk, and Compliance (GRC) tool as well as the CC data repository tool.
- d. The Contractor shall provide the CC Security Team with the required documentation to receive an Authorization to Operate (ATO).
- e. The NIH/CC shall perform multiple vulnerability scans of the server, the operating system, relational database management system (RDBMS), and websites via NIH agents. The vendor is responsible for remediating any vulnerabilities identified within the following timeframe:

NIH and CC Remediation Timelines		
Severity Level	Public Facing	Internal
Critical	15 days	30 days
High	30 days	60 days
Medium	60 days	90 days
Low	6 months	6 months

- f. For externally hosted systems (e.g., cloud providers) that are not scanned by NIH, the vendor must provide monthly vulnerability scan reports from the web application, database, and operating system. Scan results shall be managed and mitigated by the vendor via CC's POA&M process.

The Contractor must, at a minimum, segregate physically or logically, all test and development systems from production systems as applicable in accordance with the *HHS Standard for Segregation of Dev/Test Environments from Production*.

- a. The Contractor (and any Sub-Contractor) must protect information that is deemed sensitive from unauthorized disclosure to persons, organizations or Sub-Contractors who do not have a need to know the information. Information which, either alone or when compared with other reasonably-available information, is deemed sensitive or proprietary by HHS must be protected as instructed in accordance with the magnitude of the loss or harm that could result from inadvertent or deliberate disclosure, alteration, or destruction of the data. This also applies to all Sub-Contractors performing under the contract.